



Advanced Nmap

USING NMAP TO SCAN FIREWALLS

Part—6

The previous article detailed methods to scan an IPcop-based firewall in a test environment. The scan output revealed several open ports, which could lead to various vulnerabilities. Based on the scan results, several recommendations were given to secure the firewall better. Now, it is time to verify whether these recommendations have been implemented. Of course, the tool to be used for verification is Nmap.

A small recap: to scan a firewall effectively, you must check all open ports, their status, and the services running on them. The best strategy is to use as many scan types as possible. Combine all of them and arrive at the final list of ports and corresponding services. While scanning, do not forget to use Nmap timing options to fine-tune the scan and get fast results. Table 1 gives details on the basics of firewall scanning.

Table 1: Firewall scanning details

Port status	Port type	Details
Blocked	Closed port	Most of the firewall ports should be in a closed state
Filtered	Filtered port	A few ports may be filtered to restrict the access of the running services to a few IP addresses
Allowed	Open port	Very few ports should be in an open state. Whenever you find them, do not forget to probe further and close non-required ports.

The test set-up is as follows:

- Nmap PC: SUSE Linux; 192.168.1.201 (scans performed with root privileges)
- Firewall Internet (Red) port: PPPoE IP 117.x.x.x
- Firewall Internal (Green) port: 192.168.1.1

Before we begin, let's have a quick review of the recommendations:

- Firewall HTTPS interface (TCP port 775) is being used for remote management. This should be enabled only at the time of remote management/reconfiguration.
- Disable the transparent proxy mode of the firewall
- Restrict HTTPS and SSH access to the firewall only to the MAC address of the administrator PC.
- Further scan all remaining ports (1001-65535) to identify running services.
- Reconfigure the firewall to provide the NTP service on the internal network.

Now, let us go ahead with the actual interrogatory scans.

Earlier, Port 775 was found to be open by a TCP Connect scan and a SYN scan. We run both these scans again, as shown in Table 2. (Some of the lines in the actual scan result were removed for space constraints.)